



Fortify Audit Workbench

OWASP Top 10 2025

Fortifymvp



Table of Contents

[Executive Summary](#)

[Project Description](#)

[Issue Breakdown](#)

[Issue Details](#)

[A01 Broken Access Control](#)

[A02 Security Misconfiguration](#)

[A03 Software Supply Chain Failures](#)

[A04 Cryptographic Failures](#)

[A05 Injection](#)

[A06 Insecure Design](#)

[A07 Authentication Failures](#)

[A08 Software and Data Integrity Failures](#)

[A09 Logging and Alerting Failures](#)

[A10 Mishandling of Exceptional Conditions](#)

[Description of Key Terminology](#)

[About Fortify Solutions](#)

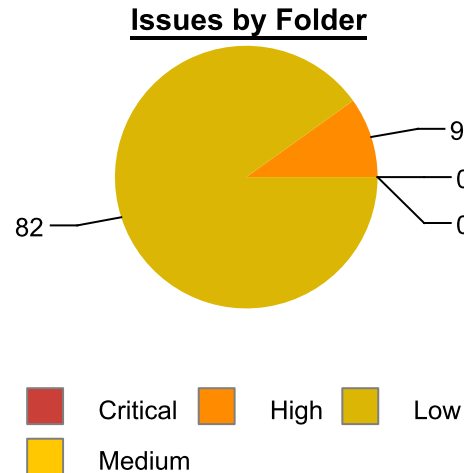
© Copyright 2008-2026 Open Text. The only warranties for products and services of Open Text and its affiliates and licensors ("Open Text") are as may be set forth in the express warranty statements accompanying such products and services. Nothing herein should be construed as constituting an additional warranty. Open Text shall not be liable for technical or editorial errors or omissions contained herein. The information contained herein is subject to change without notice.



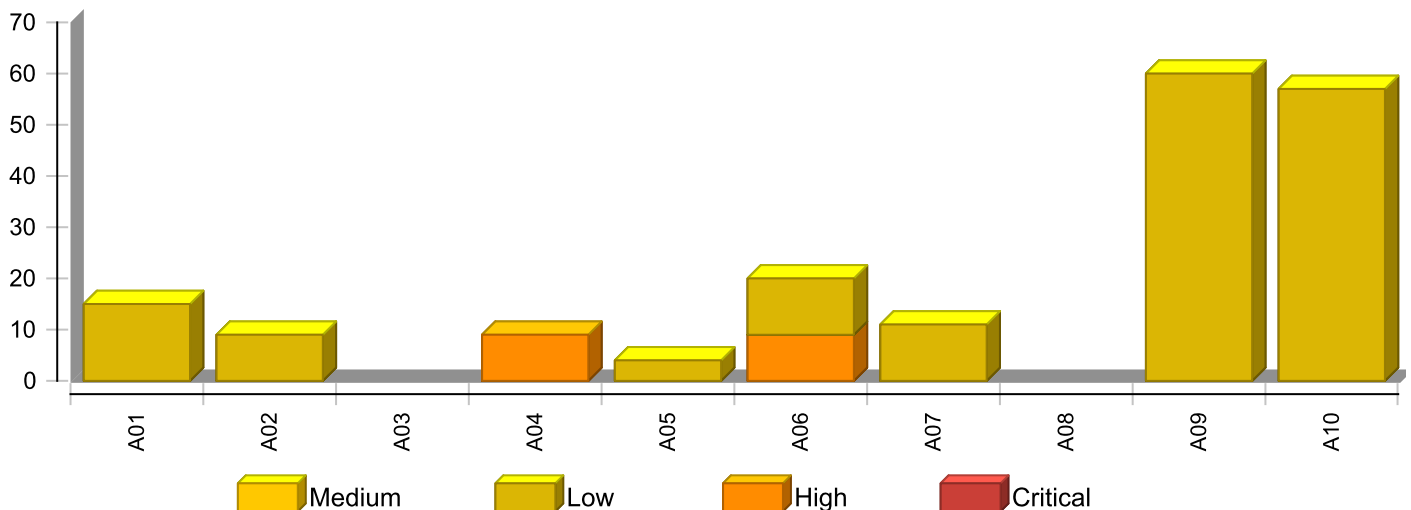
Executive Summary

OWASP Top 10 2025 提供了一份強大的 Web 應用程式安全性意識文件，將重點放在讓社群瞭解最常見和最重要的 Web 應用程式安全性弱點的後果。OWASP Top 10 呈現出對於最關鍵 Web 應用程式安全性漏洞的廣泛共識，並從資料收集和調查結果中取得共識。專案成員包括來自世界各地的各種安全專家，在他們彼此分享專業知識之下，產生了這份清單。

Project Name: Fortifymvp
Project Version:
SCA: Results Present
WebInspect: Results Not Present
WebInspect Agent: Results Not Present
Other: Results Not Present
Remediation Effort (Hrs): 3.6



Issues by OWASP Top 10 2025 Categories



* The detailed sections following the Executive Summary contain specifics.



Project Description

This section provides an overview of the Fortify scan engines used for this project, as well as the project meta-information.

SCA

Date of Last Analysis:	2026年7月7日 上午11:00	Engine Version:	26.2.0.0071
Host Name:	TPEBNKSCAAP10TT	Certification:	VALID
Number of Files:	20	Lines of Code:	6,586
Rulepack Name		Rulepack Version	
Fortify 安全編碼規則、社群、Cloud		2026.2.1.0001	
Fortify 安全編碼規則、社群、Universal		2026.2.1.0001	
Fortify 安全編碼規則、核心、Android		2026.2.1.0001	
Fortify 安全編碼規則、核心、Annotations		2026.2.1.0001	
Fortify 安全編碼規則、核心、Cloud		2026.2.1.0001	
Fortify 安全編碼規則、核心、Java		2026.2.1.0001	
Fortify 安全編碼規則、核心、Universal		2026.2.1.0001	
Fortify 安全編碼規則、延伸、配置		2026.2.1.0001	
Fortify 安全編碼規則、延伸、內容		2026.2.1.0001	
Fortify 安全編碼規則、延伸、Java		2026.2.1.0001	
Fortify 安全編碼規則、延伸、JSP		2026.2.1.0001	



Issue Breakdown

The following table summarizes the number of issues identified across the different OWASP Top 10 2025 categories and broken down by Fortify Priority Order.

	Folder	Issues	Audited	Effort (Hrs)
A01 Broken Access Control		15	0	1.2
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	15	0	
A02 Security Misconfiguration		9	0	0.6
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	9	0	
A03 Software Supply Chain Failures		0	0	0.0
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	0	0	
A04 Cryptographic Failures		9	0	0.4
	Critical	0	0	
	High	9	0	
	Medium	0	0	
	Low	0	0	
A05 Injection		4	0	0.3
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	4	0	
A06 Insecure Design		20	0	1.3
	Critical	0	0	
	High	9	0	
	Medium	0	0	
	Low	11	0	
A07 Authentication Failures		11	0	1.1
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	11	0	
A08 Software and Data Integrity Failures		0	0	0.0
	Critical	0	0	
	High	0	0	
	Medium	0	0	



	Folder	Issues	Audited	Effort (Hrs)
A08 Software and Data Integrity Failures		0	0	0.0
	Low	0	0	
A09 Logging and Alerting Failures		60	0	2.4
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	60	0	
A10 Mishandling of Exceptional Conditions		57	0	2.2
	Critical	0	0	
	High	0	0	
	Medium	0	0	
	Low	57	0	

NOTE:

1. Reported issues in the above table may violate more than one OWASP Top 10 2025 category. As such, the same issue may appear in more than one row. The total number of unique vulnerabilities are reported in the Executive Summary table.
2. For the same reason, the Project-level remediation effort total shown in the Executive Summary removes the effect of any duplication and may be smaller than the sum of the remediation effort per individual category.
3. Similarly, the remediation effort per external category is not intended to equal the sum of the remediation effort from the issue details section since individual files may contain issues in multiple Fortify priorities or audit folders.



Issue Details

Below is an enumeration of all issues found in the project. The issues are organized by OWASP Top 10 2025, Folder, and vulnerability category. The issues are then further broken down by the package, namespace, or location in which they occur. Issues reported at the same line number with the same category originate from different taint sources.



A01 Broken Access Control

A01 Broken Access Control 稱：「存取控制會強制執行原則，讓使用者不能在指定權限之外採取行動。否則通常會導致未經授權的資訊洩露、修改或破壞所有資料，或在使用者限制之外執行業務功能。常見的 Access Control 漏洞包括：- 違反了最小權限原則 (通常稱為預設拒絕)，本應只授予特定功能、角色或使用者的存取權限，卻對任何人開放。- 透過修改 URL (篡改參數或強制瀏覽)、內部應用程式狀態或 HTML 頁面，或使用修改 API 要求的攻擊工具來繞過 Access Control 檢查。- 允許透過提供唯一識別碼來檢視或編輯他人的帳戶 (不安全的直接物件參考) - 可存取的 API 缺少對 POST、PUT 和 DELETE 操作的存取控制。權限提升。未登入即以一般使用者身分操作，或以一般使用者身分登入卻能以管理員權限操作。- 中繼資料操控，例如重送或篡改 JSON Web Token (JWT) Access Control 權杖、操控 Cookie 或隱藏欄位以提升權限，或濫用 JWT 失效機制。CORS 組態錯誤導致 API 可被未授權或不受信任的來源存取。- 強制未經驗證的使用者瀏覽 (猜測 URL) 已驗證頁面，或強制標準使用者瀏覽特殊權限頁面。」

Password Management Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:303	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/AiEmailResultRptServ.java:352	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/GenAiCallingRptServ.java:333	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/GenAiCallingRptServ.java:368	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportCsvData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/ImportAiResultServ.java:403	Sink: java.sql.DriverManager.getConnection() Enclosing Method: querySqlServer() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.ImportAiResultServ.readSqlConfig() In serv/ImportAiResultServ.java:485	SCA
System Information Leak Remediation Effort(Hrs): 0.1		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/EmailWsClient.java:70	Sink: printStackTrace() Enclosing Method: sendMail() Source:	SCA

A01 Broken Access Control

A01 Broken Access Control 稱：「存取控制會強制執行原則，讓使用者不能在指定權限之外採取行動。否則通常會導致未經授權的資訊洩露、修改或破壞所有資料，或在使用者限制之外執行業務功能。常見的 Access Control 漏洞包括：- 違反了最小權限原則 (通常稱為預設拒絕)，本應只授予特定功能、角色或使用者的存取權限，卻對任何人開放。- 透過修改 URL (篡改參數或強制瀏覽)、內部應用程式狀態或 HTML 頁面，或使用修改 API 要求的攻擊工具來繞過 Access Control 檢查。- 允許透過提供唯一識別碼來檢視或編輯他人的帳戶 (不安全的直接物件參考) - 可存取的 API 缺少對 POST、PUT 和 DELETE 操作的存取控制。權限提升。未登入即以一般使用者身分操作，或以一般使用者身分登入卻能以管理員權限操作。- 中繼資料操控，例如重送或篡改 JSON Web Token (JWT) Access Control 權杖、操控 Cookie 或隱藏欄位以提升權限，或濫用 JWT 失效機制。CORS 組態錯誤導致 API 可被未授權或不受信任的來源存取。- 強制未經驗證的使用者瀏覽 (猜測 URL) 已驗證頁面，或強制標準使用者瀏覽特殊權限頁面。」

System Information Leak: Internal Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:153	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.AiEmailResultRptServ.execute() In serv/AiEmailResultRptServ.java:153	SCA
serv/AiEmailResultRptServ.java:250	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.AiEmailResultRptServ.runProcess() In serv/AiEmailResultRptServ.java:250	SCA
serv/GenAiCallingRptServ.java:147	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.runProcess() In serv/GenAiCallingRptServ.java:244	SCA
serv/GenAiCallingRptServ.java:147	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.execute() In serv/GenAiCallingRptServ.java:147	SCA
serv/GenAiCallingRptServ.java:255	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.runProcess() In serv/GenAiCallingRptServ.java:255	SCA
serv/ImportAiResultServ.java:143	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.ImportAiResultServ.execute() In serv/ImportAiResultServ.java:143	SCA
serv/ImportAiResultServ.java:282	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.ImportAiResultServ.runProcess() In serv/ImportAiResultServ.java:282	SCA
serv/ImportAiResultToProcessServ.java:298	Sink: org.slf4j.Logger.error() Enclosing Method: readExcel() Source: Read ex from com.fubon.mvp.serv.ImportAiResultToProcessServ.readExcel() In serv/ImportAiResultToProcessServ.java:298	SCA



A01 Broken Access Control

A01 Broken Access Control 稱：「存取控制會強制執行原則，讓使用者不能在指定權限之外採取行動。否則通常會導致未經授權的資訊洩露、修改或破壞所有資料，或在使用者限制之外執行業務功能。常見的 Access Control 漏洞包括：- 違反了最小權限原則 (通常稱為預設拒絕)，本應只授予特定功能、角色或使用者的存取權限，卻對任何人開放。- 透過修改 URL (篡改參數或強制瀏覽)、內部應用程式狀態或 HTML 頁面，或使用修改 API 要求的攻擊工具來繞過 Access Control 檢查。- 允許透過提供唯一識別碼來檢視或編輯他人的帳戶 (不安全的直接物件參考) - 可存取的 API 缺少對 POST、PUT 和 DELETE 操作的存取控制。權限提升。未登入即以一般使用者身分操作，或以一般使用者身分登入卻能以管理員權限操作。- 中繼資料操控，例如重送或篡改 JSON Web Token (JWT) Access Control 權杖、操控 Cookie 或隱藏欄位以提升權限，或濫用 JWT 失效機制。CORS 組態錯誤導致 API 可被未授權或不受信任的來源存取。- 強制未經驗證的使用者瀏覽 (猜測 URL) 已驗證頁面，或強制標準使用者瀏覽特殊權限頁面。」

System Information Leak: Internal Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/MvpAiResultServ.java:382	Sink: org.slf4j.Logger.error() Enclosing Method: readExcel() Source: Read ex from com.fubon.mvp.serv.MvpAiResultServ.readExcel() In serv/MvpAiResultServ.java:382	SCA

A02 Security Misconfiguration

A02 Security Misconfiguration 稱：「安全性組態錯誤是指系統、應用程式或雲端服務在安全性層面上設定不當，進而產生漏洞。應用程式可能存在漏洞，如果：- 在應用程式堆疊的任何部分中，缺少適當的安全強化或對雲端服務的權限設定不正確。- 啟用或安裝了不必要的功能 (例如，不必要的連接埠、服務、頁面、帳戶、測試架構或權限)。- 預設帳戶及其密碼仍處於啟用狀態且未更改。- 缺乏用於攔截過多錯誤訊息的集中組態。錯誤處理向使用者顯示堆疊軌跡或其他資訊過多的錯誤訊息。- 對於已升級的系統，最新的安全功能被停用或未安全設定。- 過度優先考量向下相容性，導致不安全的組態。- 應用程式伺服器、應用程式架構 (例如，Struts、Spring、ASP.NET)、程式庫、資料庫等項目中的安全設定未設定為安全值。- 伺服器不會傳送安全性標頭或指令，或者它們未設定為安全值。如果沒有一套一致且可重複執行的應用程式安全組態強化流程，系統將面臨更高的風險。」

System Information Leak: Internal Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:153	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.AiEmailResultRptServ.execute() In serv/AiEmailResultRptServ.java:153	SCA
serv/AiEmailResultRptServ.java:250	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.AiEmailResultRptServ.runProcess() In serv/AiEmailResultRptServ.java:250	SCA
serv/GenAiCallingRptServ.java:147	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.runProcess() In serv/GenAiCallingRptServ.java:244	SCA
serv/GenAiCallingRptServ.java:147	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.execute() In serv/GenAiCallingRptServ.java:147	SCA
serv/GenAiCallingRptServ.java:255	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.GenAiCallingRptServ.runProcess() In serv/GenAiCallingRptServ.java:255	SCA
serv/ImportAiResultServ.java:143	Sink: org.slf4j.Logger.error() Enclosing Method: execute() Source: Read e from com.fubon.mvp.serv.ImportAiResultServ.execute() In serv/ImportAiResultServ.java:143	SCA
serv/ImportAiResultServ.java:282	Sink: org.slf4j.Logger.warn() Enclosing Method: runProcess() Source: Read e from com.fubon.mvp.serv.ImportAiResultServ.runProcess() In serv/ImportAiResultServ.java:282	SCA
serv/ImportAiResultToProcessServ.java:298	Sink: org.slf4j.Logger.error() Enclosing Method: readExcel() Source: Read ex from com.fubon.mvp.serv.ImportAiResultToProcessServ.readExcel() In serv/ImportAiResultToProcessServ.java:298	SCA

A02 Security Misconfiguration

A02 Security Misconfiguration 稱：「安全性組態錯誤是指系統、應用程式或雲端服務在安全性層面上設定不當，進而產生漏洞。應用程式可能存在漏洞，如果：- 在應用程式堆疊的任何部分中，缺少適當的安全強化或對雲端服務的權限設定不正確。- 啟用或安裝了不必要的功能 (例如，不必要的連接埠、服務、頁面、帳戶、測試架構或權限)。- 預設帳戶及其密碼仍處於啟用狀態且未更改。- 缺乏用於攔截過多錯誤訊息的集中組態。錯誤處理向使用者顯示堆疊軌跡或其他資訊過多的錯誤訊息。- 對於已升級的系統，最新的安全功能被停用或未安全設定。- 過度優先考量向下相容性，導致不安全的組態。- 應用程式伺服器、應用程式架構 (例如，Struts、Spring、ASP.NET)、程式庫、資料庫等項目中的安全設定未設定為安全值。- 伺服器不會傳送安全性標頭或指令，或者它們未設定為安全值。如果沒有一套一致且可重複執行的應用程式安全組態強化流程，系統將面臨更高的風險。」

System Information Leak: Internal Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/MvpAiResultServ.java:382	Sink: org.slf4j.Logger.error() Enclosing Method: readExcel() Source: Read ex from com.fubon.mvp.serv.MvpAiResultServ.readExcel() In serv/MvpAiResultServ.java:382	SCA

A03 Software Supply Chain Failures

A03 Software Supply Chain Failures 稱：「軟體供應鏈故障是指在軟體建置、散佈或更新過程中發生的故障或其他形式的入侵。這類問題通常是由系統所依賴的第三方程式碼、工具或其他相依項中的漏洞或惡意變更所導致。您的系統可能存在漏洞，如果：- 如果您沒有仔細追蹤您使用的所有元件的版本 (用戶端和伺服器端)。這包括您直接使用的元件以及巢狀 (遞移) 相依項。- 軟體存在漏洞、不受支援或已過時。這包括作業系統、Web/應用程式伺服器、資料庫管理系統 (DBMS)、應用程式、API 和所有元件、執行階段環境和程式庫。- 未定期掃描漏洞並訂閱與所使用元件相關的安全公告。- 如果您沒有變更管理流程，或未能追蹤供應鏈中的變更，包括 IDE、IDE 擴充套件與更新、組織程式碼儲存庫的變更、沙箱、映像與函式庫儲存庫，以及建立與儲存構件的方式等。供應鏈中的每一個環節都應被記錄，尤其是所有變更。- 如果您尚未對供應鏈的每一個環節進行安全強化，特別是 Access Control 與最小權限原則的落實。- 如果您的供應鏈系統沒有職責分離機制。不應讓任何人員在沒有其他人為監督的情況下，同時負責寫程式碼並一路將其推送到生產環境。- 如果允許開發人員、DevOps 或基礎架構專業人員從不受信任的來源下載並在生產環境中使用元件。- 未根據風險及時修正或升級基礎平台、架構及相依項。這通常發生在變更控制下實施每月或每季修補工作的環境，進而造成組織在修正漏洞之前可能會面臨數天或數月的不必要風險暴露。- 軟體開發人員不測試更新、升級或修補後的程式庫相容性。- 如果您沒有保護系統每個部分的組態 (請參閱 A02:2025-Security Misconfiguration)。- 如果您有一個使用許多元件的複雜 CI/CD 管道，但其安全性比應用程式的其他部分脆弱。」

No Issues



A04 Cryptographic Failures

A04 Cryptographic Failures 稱：「一般而言，所有傳輸中的資料都應該在傳輸層 (OSI 第 4 層) 進行加密。過去的障礙，例如 CPU 效能以及私鑰／憑證管理，如今已獲得解決：CPU 內建了可加速加密的指令 (例如：AES 支援)，而私鑰與憑證管理也因為 LetsEncrypt.org 這類服務而大幅簡化，各大雲端服務供應商更提供與其平台高度整合的憑證管理服務。除了保護傳輸層之外，也必須評估哪些資料需要在靜態儲存時加密，以及哪些資料在傳輸時需要額外的加密保護 (在應用層，OSI 第 7 層)。例如，密碼、信用卡號碼、健康記錄、個人資訊和商業機密需要額外保護，尤其是這些資料屬於歐盟的通用資料保護規則 (GDPR) 等隱私權法或 PCI 資料安全標準 (PCI DSS) 等法規之範疇時。針對所有此類資料，需檢查以下事項：- 是否在預設設定或舊有程式碼中使用了過時或薄弱的加密演算法或通訊協定？- 是否正在使用預設的加密金鑰、產生低強度加密金鑰、重複使用金鑰，或缺乏完善的金鑰管理與輪替機制？- 是否將加密金鑰簽入原始程式碼儲存庫中？- 是否未強制執行加密，例如，是否缺少任何 HTTP 標頭 (瀏覽器) 安全指令或標頭？- 是否有正確驗證接收的伺服器憑證及其信任鏈？- 初始化向量是否被忽略、重複使用，或未依加密模式需求以足夠安全的方式產生？是否使用了不安全的加密模式，例如 ECB？當驗證加密較為合適時，是否僅使用了一般加密？- 是否在未使用密碼型金鑰衍生函數的情況下，直接將密碼當作加密金鑰？- 是否使用了不符合密碼學需求的隨機性來進行加密用途？即使選擇了正確的函數，是否需要由開發人員進行植入？若不需要，開發人員是否反而以熵值或不可預測性不足的種子覆寫了函數內建的強植入功能？- 是否仍在已棄用的雜湊函數 (例如 MD5 或 SHA1)，或在需要密碼學雜湊時誤用非密碼學雜湊函數？- 是否仍在已棄用的加密填補方法，例如 PKCS number 1 v1.5？- 是否存在可被利用的加密錯誤訊息或側通道資訊，例如透過 Padding Oracle 攻擊？- 是否有可能對加密演算法進行降級或略過？」

Weak Encryption: Inadequate RSA Padding Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:281	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:286	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/ImportAiResultServ.java:304	Sink: getInstance() Enclosing Method: decryptRsaFile() Source:	SCA
Weak Encryption: Insecure Mode of Operation Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:281	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/AiEmailResultRptServ.java:500	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA
serv/GenAiCallingRptServ.java:286	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:473	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA

A04 Cryptographic Failures

A04 Cryptographic Failures 稱：「一般而言，所有傳輸中的資料都應該在傳輸層 (OSI 第 4 層) 進行加密。過去的障礙，例如 CPU 效能以及私鑰／憑證管理，如今已獲得解決：CPU 內建了可加速加密的指令 (例如：AES 支援)，而私鑰與憑證管理也因為 LetsEncrypt.org 這類服務而大幅簡化，各大雲端服務供應商更提供與其平台高度整合的憑證管理服務。除了保護傳輸層之外，也必須評估哪些資料需要在靜態儲存時加密，以及哪些資料在傳輸時需要額外的加密保護 (在應用層，OSI 第 7 層)。例如，密碼、信用卡號碼、健康記錄、個人資訊和商業機密需要額外保護，尤其是這些資料屬於歐盟的通用資料保護規則 (GDPR) 等隱私權法或 PCI 資料安全標準 (PCI DSS) 等法規之範疇時。針對所有此類資料，需檢查以下事項：- 是否在預設設定或舊有程式碼中使用了過時或薄弱的加密演算法或通訊協定？- 是否正在使用預設的加密金鑰、產生低強度加密金鑰、重複使用金鑰，或缺乏完善的金鑰管理與輪替機制？- 是否將加密金鑰簽入原始程式碼儲存庫中？- 是否未強制執行加密，例如，是否缺少任何 HTTP 標頭 (瀏覽器) 安全指令或標頭？- 是否有正確驗證接收的伺服器憑證及其信任鏈？- 初始化向量是否被忽略、重複使用，或未依加密模式需求以足夠安全的方式產生？是否使用了不安全的加密模式，例如 ECB？當驗證加密較為合適時，是否僅使用了一般加密？- 是否在未使用密碼型金鑰衍生函數的情況下，直接將密碼當作加密金鑰？- 是否使用了不符合密碼學需求的隨機性來進行加密用途？即使選擇了正確的函數，是否需要由開發人員進行植入？若不需要，開發人員是否反而以熵值或不可預測性不足的種子覆寫了函數內建的強植入功能？- 是否仍在使用已棄用的雜湊函數 (例如 MD5 或 SHA1)，或在需要密碼學雜湊時誤用非密碼學雜湊函數？- 是否仍在使用已棄用的加密填補方法，例如 PKCS number 1 v1.5？- 是否存在可被利用的加密錯誤訊息或側通道資訊，例如透過 Padding Oracle 攻擊？- 是否有可能對加密演算法進行降級或略過？」

Weak Encryption: Insecure Mode of Operation Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/ImportAiResultServ.java :304	Sink: getInstance() Enclosing Method: decryptRsaFile() Source:	SCA
serv/ImportAiResultServ.java :531	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA

A05 Injection

A05 Injection 稱：「Injection 漏洞是一種系統漏洞，是一種系統缺陷，會讓攻擊者能將惡意程式碼或指令 (例如 SQL 或殼層程式碼) 插入到程式的輸入欄位中，誘使系統將這些程式碼或命令當作系統本身的一部分來執行。這種漏洞可能造成極其嚴重的後果。以下情況，應用程式容易受到攻擊：- 應用程式不會驗證、過濾或清理使用者提供的資料。- 直接在解譯器中使用沒有內容感知逸出的動態查詢或非參數化呼叫。- 在物件關係對應 (ORM) 搜尋參數中，使用未經清理的資料來擷取額外的敏感記錄。- 直接使用或串聯潛在的惡意資料。SQL 或指令包含動態查詢、指令或已儲存程序中的結構和惡意資料。一些更常見的插入項目是 SQL、NoSQL、OS 指令、物件關係對應 (ORM)、LDAP 和運算式語言 (EL) 或物件圖形導覽程式庫 (OGNL) 插入。這個概念在所有解譯器中都是相同的。最佳的偵測方法是結合原始程式碼審查與所有參數、標頭、URL、Cookie、JSON、SOAP 和 XML 資料輸入的自動化測試 (包括模糊化測試)。在 CI/CD 管道中新增靜態 (SAST)、動態 (DAST) 和互動式 (IAST) 應用程式安全測試工具，也有助於在生產部署之前識別 Injection 漏洞。」

Log Forging Remediation Effort(Hrs): 0.3		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:200	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.AiEmailResultRptServ.queryMasterNode() In serv/AiEmailResultRptServ.java:305	SCA
serv/AiEmailResultRptServ.java:203	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.AiEmailResultRptServ.queryMasterNode() In serv/AiEmailResultRptServ.java:305	SCA
serv/GenAiCallingRptServ.java:194	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.GenAiCallingRptServ.queryMasterNode() In serv/GenAiCallingRptServ.java:335	SCA
serv/GenAiCallingRptServ.java:197	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.GenAiCallingRptServ.queryMasterNode() In serv/GenAiCallingRptServ.java:335	SCA

A06 Insecure Design

A06 Insecure Design 稱：「不安全的設計是一大類別，代表各種不同的弱點，並以『欠缺控制設計或控制設計無效』表示。不安全的設計並不是所有其他十大風險類別的來源。請注意，不安全的設計與不安全的實作是有所不同的。我們區分設計缺陷與實作缺陷是有原因的，它們的根本原因不同、發生在開發流程的不同階段，且補救方式也不同。即使設計安全，實作缺陷仍可能導致可被利用的漏洞。而不安全的設計，即使實作完美，也無法彌補，因為所需的安全控制從未建立來防禦特定攻擊。造成不安全設計的因素之一，是在開發軟體或系統時缺乏對業務風險的分析，導致未能確定所需的安全設計層級。安全的設計的三大關鍵要素是：- 收集需求與資源管理 - 建立安全設計 - 擁有安全的開發生命週期」

Often Misused: Authentication Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:198	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
serv/AiEmailResultRptServ.java:198	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:196	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:196	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
Password Management Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:303	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/AiEmailResultRptServ.java:352	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/GenAiCallingRptServ.java:333	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA

A06 Insecure Design

A06 Insecure Design 稱：「不安全的設計是一大類別，代表各種不同的弱點，並以『欠缺控制設計或控制設計無效』表示。不安全的設計並不是所有其他十大風險類別的來源。請注意，不安全的設計與不安全的實作是有所不同的。我們區分設計缺陷與實作缺陷是有原因的，它們的根本原因不同、發生在開發流程的不同階段，且補救方式也不同。即使設計安全，實作缺陷仍可能導致可被利用的漏洞。而不安全的設計，即使實作完美，也無法彌補，因為所需的安全控制從未建立來防禦特定攻擊。造成不安全設計的因素之一，是在開發軟體或系統時缺乏對業務風險的分析，導致未能確定所需的安全設計層級。安全的設計的三大關鍵要素是：- 收集需求與資源管理 - 建立安全設計 - 擁有安全的開發生命週期」

Password Management Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/GenAiCallingRptServ.java:368	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportCsvData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/ImportAiResultServ.java:403	Sink: java.sql.DriverManager.getConnection() Enclosing Method: querySqlServer() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.ImportAiResultServ.readSqlConfig() In serv/ImportAiResultServ.java:485	SCA
Weak Encryption: Inadequate RSA Padding Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:281	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:286	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/ImportAiResultServ.java:304	Sink: getInstance() Enclosing Method: decryptRsaFile() Source:	SCA
Weak Encryption: Insecure Mode of Operation Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:281	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/AiEmailResultRptServ.java:500	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA
serv/GenAiCallingRptServ.java:286	Sink: getInstance() Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA

A06 Insecure Design

A06 Insecure Design 稱：「不安全的設計是一大類別，代表各種不同的弱點，並以『欠缺控制設計或控制設計無效』表示。不安全的設計並不是所有其他十大風險類別的來源。請注意，不安全的設計與不安全的實作是有所不同的。我們區分設計缺陷與實作缺陷是有原因的，它們的根本原因不同、發生在開發流程的不同階段，且補救方式也不同。即使設計安全，實作缺陷仍可能導致可被利用的漏洞。而不安全的設計，即使實作完美，也無法彌補，因為所需的安全控制從未建立來防禦特定攻擊。造成不安全設計的因素之一，是在開發軟體或系統時缺乏對業務風險的分析，導致未能確定所需的安全設計層級。安全的设计的三大關鍵要素是： - 收集需求與資源管理 - 建立安全設計 - 擁有安全的開發生命週期」

Weak Encryption: Insecure Mode of Operation Remediation Effort(Hrs): 0.4		High
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/GenAiCallingRptServ.java:473	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA
serv/ImportAiResultServ.java:304	Sink: getInstance() Enclosing Method: decryptRsaFile() Source:	SCA
serv/ImportAiResultServ.java:531	Sink: getInstance() Enclosing Method: decodeFtpCredential() Source:	SCA



A07 Authentication Failures

A07 Authentication Failures 稱：「當攻擊者能夠誘使系統將一個無效或錯誤的使用者識別為合法使用者時，即存在此漏洞。如果應用程式符合以下情況，則可能存在驗證漏洞：- 允許憑證填充等自動攻擊，其中攻擊者擁有有效使用者名稱和密碼的外洩清單。最近，這類攻擊這類攻擊擴大至涵蓋混合型密碼攻擊，包括 Credential Stuffing (也稱為 Password Spray 攻擊)，攻擊者會使用洩漏憑證的變體或增量來取得存取權限，例如依序嘗試 Password1!、Password2!、Password3! 等。- 允許 Brute Force 或其他自動化指令碼攻擊，這些攻擊無法快速阻止。- 允許使用預設密碼、低強度密碼或眾所周知的密碼，例如「Password1」或密碼為「admin」的使用者名稱「admin。」- 允許使用者使用已知外洩的憑證建立新帳戶。- 允許使用無法確保安全的低強度或無效憑證復原和忘記密碼流程，例如「知識庫答案。」- 使用純文字、加密或弱雜湊密碼資料存放區 (請參閱 A02:2021-Cryptographic Failures)。- 缺少多重驗證或多重驗證無效。- 如果無法進行多重驗證，則允許使用低強度或無效的後援。- 將工作階段識別碼暴露在 URL、隱藏欄位或其他用戶端可存取的不安全位置。- 成功登入後重複使用相同的工作階段識別碼。在登出或閒置一段時間後，未能正確地讓使用者工作階段或驗證權杖 (主要是單一登入 (SSO) 權杖) 失效。」

Often Misused: Authentication Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:198	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
serv/AiEmailResultRptServ.java:198	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:192	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:196	Sink: getHostName() Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:196	Sink: getLocalHost() Enclosing Method: runProcess() Source:	SCA
Password Management Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:303	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA
serv/AiEmailResultRptServ.java:352	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.AiEmailResultRptServ.readSqlConfig() In serv/AiEmailResultRptServ.java:580	SCA

A07 Authentication Failures

A07 Authentication Failures 稱：「當攻擊者能夠誘使系統將一個無效或錯誤的使用者識別為合法使用者時，即存在此漏洞。如果應用程式符合以下情況，則可能存在驗證漏洞：- 允許憑證填充等自動攻擊，其中攻擊者擁有有效使用者名稱和密碼的外洩清單。最近，這類攻擊這類攻擊擴大至涵蓋混合型密碼攻擊，包括 Credential Stuffing (也稱為 Password Spray 攻擊)，攻擊者會使用洩漏憑證的變體或增量來取得存取權限，例如依序嘗試 Password1!、Password2!、Password3! 等。- 允許 Brute Force 或其他自動化指令碼攻擊，這些攻擊無法快速阻止。- 允許使用預設密碼、低強度密碼或眾所周知的密碼，例如「Password1」或密碼為「admin」的使用者名稱「admin。」- 允許使用者使用已知外洩的憑證建立新帳戶。- 允許使用無法確保安全的低強度或無效憑證復原和忘記密碼流程，例如「知識庫答案。」- 使用純文字、加密或弱雜湊密碼資料存放區 (請參閱 A02:2021-Cryptographic Failures)。- 缺少多重驗證或多重驗證無效。- 如果無法進行多重驗證，則允許使用低強度或無效的後援。- 將工作階段識別碼暴露在 URL、隱藏欄位或其他用戶端可存取的不安全位置。- 成功登入後重複使用相同的工作階段識別碼。在登出或閒置一段時間後，未能正確地讓使用者工作階段或驗證權杖 (主要是單一登入 (SSO) 權杖) 失效。」

Password Management Remediation Effort(Hrs): 0.7		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/GenAiCallingRptServ.java:333	Sink: java.sql.DriverManager.getConnection() Enclosing Method: queryMasterNode() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/GenAiCallingRptServ.java:368	Sink: java.sql.DriverManager.getConnection() Enclosing Method: exportCsvData() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.GenAiCallingRptServ.readSqlConfig() In serv/GenAiCallingRptServ.java:553	SCA
serv/ImportAiResultServ.java:403	Sink: java.sql.DriverManager.getConnection() Enclosing Method: querySqlServer() Source: java.nio.file.Files.readAllLines() from com.fubon.mvp.serv.ImportAiResultServ.readSqlConfig() In serv/ImportAiResultServ.java:485	SCA

A08 Software and Data Integrity Failures

A08 Software or Data Integrity Failures 稱：「軟體與資料完整性故障指的是程式碼與基礎架構未能防範將無效或不受信任的程式碼或資料當作可信且有效來處理的情況。這種情況的一個例子就是，應用程式所依賴的外掛程式、程式庫或模組來自不受信任的來源、存放庫和內容傳遞網路 (CDN)。一個不進行軟體完整性檢查的 CI/CD 管道可能會引入未授權存取、不安全或惡意程式碼，甚至導致系統遭受入侵的風險。另一個例子是 CI/CD 從不受信任的位置提取程式碼或構件，並且/或在使用前不對其進行驗證 (例如透過檢查簽章或類似機制)。最後，現在的許多應用程式都包括自動更新功能，而更新在沒有充分驗證完整性的情況下被下載並套用於以前信任的應用程式。攻擊者可能會上傳自己的更新以散發在所有安裝上執行。另一個例子是物件或資料被編碼或序列化到一個結構中，而攻擊者可以看到和修改這個結構，進而容易遭受不安全的還原序列化。」

No Issues



A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Log Forging Remediation Effort(Hrs): 0.3		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:200	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.AiEmailResultRptServ.queryMasterNode() In serv/AiEmailResultRptServ.java:305	SCA
serv/AiEmailResultRptServ.java:203	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.AiEmailResultRptServ.queryMasterNode() In serv/AiEmailResultRptServ.java:305	SCA
serv/GenAiCallingRptServ.java:194	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.GenAiCallingRptServ.queryMasterNode() In serv/GenAiCallingRptServ.java:335	SCA
serv/GenAiCallingRptServ.java:197	Sink: org.slf4j.Logger.info() Enclosing Method: runProcess() Source: java.sql.Statement.executeQuery() from com.fubon.mvp.serv.GenAiCallingRptServ.queryMasterNode() In serv/GenAiCallingRptServ.java:335	SCA
Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.ctrl		
Location	Analysis Info	Analyzer
ctrl/MvpApiCtrl.java:243	Sink: CatchBlock Enclosing Method: aiResultImport() Source:	SCA
ctrl/MvpApiCtrl.java:340	Sink: CatchBlock Enclosing Method: genAiCallingRptTrigger() Source:	SCA

A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.ctrl		
Location	Analysis Info	Analyzer
ctrl/MvpApiController.java:368	Sink: CatchBlock Enclosing Method: importAiResultTrigger() Source:	SCA
ctrl/MvpApiController.java:396	Sink: CatchBlock Enclosing Method: AiEmailResultRptTrigger() Source:	SCA
Package: com.fubon.mvp.dao		
Location	Analysis Info	Analyzer
dao/EmailDao.java:194	Sink: CatchBlock Enclosing Method: save() Source:	SCA
dao/EmailDao.java:210	Sink: CatchBlock Enclosing Method: save() Source:	SCA
dao/EmailHostDao.java:108	Sink: CatchBlock Enclosing Method: save() Source:	SCA
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:159	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:160	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:161	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA

A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:162	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:163	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:164	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:165	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:166	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:167	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:168	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:169	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:170	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:171	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:172	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA



A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:173	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:174	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:177	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:178	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:179	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:180	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:152	Sink: CatchBlock Enclosing Method: execute() Source:	SCA
serv/EmailWsClient.java:69	Sink: CatchBlock Enclosing Method: sendMail() Source:	SCA
serv/GenAiCallingRptServ.java:146	Sink: CatchBlock Enclosing Method: execute() Source:	SCA

A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/ImportAiResultServ.java:142	Sink: CatchBlock Enclosing Method: execute() Source:	SCA
serv/Mvc310004Serv.java:71	Sink: CatchBlock Enclosing Method: service() Source:	SCA
serv/Mvc310005Serv.java:92	Sink: CatchBlock Enclosing Method: service() Source:	SCA
serv/Mvp110007Serv.java:209	Sink: CatchBlock Enclosing Method: schedule() Source:	SCA
serv/Mvp110008Serv.java:269	Sink: CatchBlock Enclosing Method: schedule() Source:	SCA
serv/MvpAiResultServ.java:186	Sink: CatchBlock Enclosing Method: processOverdueAiCalling() Source:	SCA
serv/MvpAiResultServ.java:235	Sink: CatchBlock Enclosing Method: callCoreApi() Source:	SCA
Poor Error Handling: Overly Broad Throws Remediation Effort(Hrs): 0.6		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:160	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/AiEmailResultRptServ.java:257	Sink: Function: decryptWithRsaPrivateKey Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA



A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Throws Remediation Effort(Hrs): 0.6		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:333	Sink: Function: exportData Enclosing Method: exportData() Source:	SCA
serv/AiEmailResultRptServ.java:370	Sink: Function: exportExcel Enclosing Method: exportExcel() Source:	SCA
serv/AiEmailResultRptServ.java:436	Sink: Function: processFtpUpload Enclosing Method: processFtpUpload() Source:	SCA
serv/AiEmailResultRptServ.java:525	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA
serv/AiEmailResultRptServ.java:545	Sink: Function: uploadFileViaFtp Enclosing Method: uploadFileViaFtp() Source:	SCA
serv/GenAiCallingRptServ.java:154	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:262	Sink: Function: decryptWithRsaPrivateKey Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:362	Sink: Function: exportCsvData Enclosing Method: exportCsvData() Source:	SCA
serv/GenAiCallingRptServ.java:409	Sink: Function: processFtpUpload Enclosing Method: processFtpUpload() Source:	SCA
serv/GenAiCallingRptServ.java:498	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA
serv/GenAiCallingRptServ.java:518	Sink: Function: uploadFileViaFtp Enclosing Method: uploadFileViaFtp() Source:	SCA



A09 Logging and Alerting Failures

A09 Logging and Alerting Failures 稱：「如果沒有記錄和監控，就無法偵測攻擊和入侵；如果沒有警示，則在安全事件發生時很難快速且有效地做出回應。記錄、持續監控、偵測和警示不足，以致無法啟動主動回應的情況包括：- 可稽核的事件，例如登入、登入失敗和高價值交易，沒有被記錄或記錄不一致（例如，只記錄成功的登入，而不記錄失敗的嘗試）。- 警告和錯誤不會產生、不充分或不清楚的記錄訊息。- 記錄的完整性沒有得到妥善保護，容易被竄改。- 未監控應用程式和 API 的記錄是否存在可疑活動。- 記錄僅儲存在本機，沒有進行妥善備份。- 適當的警示閾值和回應提報流程沒有實施或無效。警示未在合理時間內收到或檢閱。- 動態應用程式安全測試 (DAST) 工具 (例如 Burp 或 ZAP) 所執行的滲透測試和掃描不會觸發警示。- 應用程式無法即時或近乎即時地偵測、提報或警示有關活躍的攻擊。- 如果使用者或攻擊者可以看到記錄和警示事件 (請參閱 A01:2025-Broken Access Control)，或記錄了不應記錄的敏感資訊 (例如 PII 或 PHI)，則容易導致敏感資訊外洩。- 如果記錄資料未正確編碼，系統容易受到 Injection 攻擊或對記錄/監控系統的攻擊。- 應用程式缺少錯誤或不當處理錯誤及其他例外情況，導致系統無法察覺錯誤，因此無法記錄問題。- 缺乏足夠的「使用案例」來發出警示，或使用案例已過時，無法識別特殊情況。- 過多的誤報會導致無法區分重要警示和不重要警示，結果警示可能太晚被察覺或根本未被察覺 (SOC 團隊的體力負荷過重)。- 偵測到的警示無法正確處理，因為使用案例的操作手冊不完整、過時或缺失。」

Poor Error Handling: Overly Broad Throws Remediation Effort(Hrs): 0.6		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/ImportAiResultServ.java:150	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:298	Sink: Function: decryptRsaFile Enclosing Method: decryptRsaFile() Source:	SCA
serv/ImportAiResultServ.java:318	Sink: Function: loadRsaPrivateKey Enclosing Method: loadRsaPrivateKey() Source:	SCA
serv/ImportAiResultServ.java:399	Sink: Function: querySqlServer Enclosing Method: querySqlServer() Source:	SCA
serv/ImportAiResultServ.java:436	Sink: Function: downloadFromFtp Enclosing Method: downloadFromFtp() Source:	SCA
serv/ImportAiResultServ.java:556	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA

A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.ctrl		
Location	Analysis Info	Analyzer
ctrl/MvpApiCtrl.java:243	Sink: CatchBlock Enclosing Method: aiResultImport() Source:	SCA
ctrl/MvpApiCtrl.java:340	Sink: CatchBlock Enclosing Method: genAiCallingRptTrigger() Source:	SCA
ctrl/MvpApiCtrl.java:368	Sink: CatchBlock Enclosing Method: importAiResultTrigger() Source:	SCA
ctrl/MvpApiCtrl.java:396	Sink: CatchBlock Enclosing Method: AiEmailResultRptTrigger() Source:	SCA
Package: com.fubon.mvp.dao		
Location	Analysis Info	Analyzer
dao/EmailDao.java:194	Sink: CatchBlock Enclosing Method: save() Source:	SCA
dao/EmailDao.java:210	Sink: CatchBlock Enclosing Method: save() Source:	SCA
dao/EmailHostDao.java:108	Sink: CatchBlock Enclosing Method: save() Source:	SCA
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:159	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:160	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:161	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA

A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:162	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:163	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:164	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:165	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:166	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:167	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:168	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:169	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:170	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:171	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:172	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:173	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:174	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA



A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.data		
Location	Analysis Info	Analyzer
data/EmailMaster.java:177	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:178	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:179	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
data/EmailMaster.java:180	Sink: CatchBlock Enclosing Method: EmailMaster() Source:	SCA
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:152	Sink: CatchBlock Enclosing Method: execute() Source:	SCA
serv/EmailWsClient.java:69	Sink: CatchBlock Enclosing Method: sendMail() Source:	SCA
serv/GenAiCallingRptServ.java:146	Sink: CatchBlock Enclosing Method: execute() Source:	SCA
serv/ImportAiResultServ.java:142	Sink: CatchBlock Enclosing Method: execute() Source:	SCA
serv/Mvc310004Serv.java:71	Sink: CatchBlock Enclosing Method: service() Source:	SCA
serv/Mvc310005Serv.java:92	Sink: CatchBlock Enclosing Method: service() Source:	SCA
serv/Mvp110007Serv.java:209	Sink: CatchBlock Enclosing Method: schedule() Source:	SCA

A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Poor Error Handling: Overly Broad Catch Remediation Effort(Hrs): 1.9		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/Mvp110008Serv.java:269	Sink: CatchBlock Enclosing Method: schedule() Source:	SCA
serv/MvpAiResultServ.java:186	Sink: CatchBlock Enclosing Method: processOverdueAiCalling() Source:	SCA
serv/MvpAiResultServ.java:235	Sink: CatchBlock Enclosing Method: callCoreApi() Source:	SCA
Poor Error Handling: Overly Broad Throws Remediation Effort(Hrs): 0.6		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/AiEmailResultRptServ.java:160	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/AiEmailResultRptServ.java:257	Sink: Function: decryptWithRsaPrivateKey Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/AiEmailResultRptServ.java:333	Sink: Function: exportData Enclosing Method: exportData() Source:	SCA
serv/AiEmailResultRptServ.java:370	Sink: Function: exportExcel Enclosing Method: exportExcel() Source:	SCA
serv/AiEmailResultRptServ.java:436	Sink: Function: processFtpUpload Enclosing Method: processFtpUpload() Source:	SCA
serv/AiEmailResultRptServ.java:525	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA
serv/AiEmailResultRptServ.java:545	Sink: Function: uploadFileViaFtp Enclosing Method: uploadFileViaFtp() Source:	SCA

A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Poor Error Handling: Overly Broad Throws Remediation Effort(Hrs): 0.6		Low
Package: com.fubon.mvp.serv		
Location	Analysis Info	Analyzer
serv/GenAiCallingRptServ.java:154	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/GenAiCallingRptServ.java:262	Sink: Function: decryptWithRsaPrivateKey Enclosing Method: decryptWithRsaPrivateKey() Source:	SCA
serv/GenAiCallingRptServ.java:362	Sink: Function: exportCsvData Enclosing Method: exportCsvData() Source:	SCA
serv/GenAiCallingRptServ.java:409	Sink: Function: processFtpUpload Enclosing Method: processFtpUpload() Source:	SCA
serv/GenAiCallingRptServ.java:498	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA
serv/GenAiCallingRptServ.java:518	Sink: Function: uploadFileViaFtp Enclosing Method: uploadFileViaFtp() Source:	SCA
serv/ImportAiResultServ.java:150	Sink: Function: runProcess Enclosing Method: runProcess() Source:	SCA
serv/ImportAiResultServ.java:298	Sink: Function: decryptRsaFile Enclosing Method: decryptRsaFile() Source:	SCA
serv/ImportAiResultServ.java:318	Sink: Function: loadRsaPrivateKey Enclosing Method: loadRsaPrivateKey() Source:	SCA
serv/ImportAiResultServ.java:399	Sink: Function: querySqlServer Enclosing Method: querySqlServer() Source:	SCA
serv/ImportAiResultServ.java:436	Sink: Function: downloadFromFtp Enclosing Method: downloadFromFtp() Source:	SCA
serv/ImportAiResultServ.java:556	Sink: Function: evpBytesToKey Enclosing Method: evpBytesToKey() Source:	SCA

A10 Mishandling of Exceptional Conditions

A10 Mishandling of Exceptional Conditions 稱：「軟體中對例外狀況的錯誤處理是指程式無法預防、偵測或回應不尋常且不可預測的情況，導致當機、意外行為，有時甚至產生漏洞。這可能涉及以下 3 種缺陷中的一種或多種：應用程式未能預防異常情況的發生；未能識別正在發生的異常情況；和/或事後對異常情況的反應不佳或根本沒有回應。例外狀況可能由以下原因引起：輸入驗證缺失、不完善或不完整，或者在發生異常情況的函數中沒有進行及時、高階的錯誤處理；意外的環境狀態，如記憶體、權限或網路問題；不一致的例外處理；或完全未處理的例外，導致系統進入未知且不可預測的狀態。每當應用程式不確定下一個指令時，就表示例外狀況被錯誤處理。難以發現的錯誤和例外可能長期威脅整個應用程式的安全性。如果例外狀況處理不當，可能會出現許多不同的安全漏洞，例如邏輯錯誤、溢位、競爭條件、詐欺交易，或記憶體、狀態、資源、時序、驗證和授權方面的問題。這些類型的漏洞會對系統或其資料的機密性、可用性和/或完整性造成負面影響。攻擊者會操控應用程式的異常錯誤處理機制來攻擊此漏洞。」

Redundant Null Check <i>Remediation Effort(Hrs): 0.1</i>		Low
Package: com.fubon.mvp.dao		
Location	Analysis Info	Analyzer
dao/EmailHostDao.java:52	Sink: Dereferenced : this.entity Enclosing Method: initial() Source:	SCA